INTERNAL ACCESS REVIEW

Admin Role Access Report — Who Sees What

What each of the four admin roles actually sees in the sidebar, and — separately — whether the data behind each page is genuinely scoped to that role or just hidden from the menu while remaining fully open to anyone who types the URL.

Roles covered

Superadmin · Admin · Staff · Agent

Method

Full code trace, file:line cited

Date

2 October 2026

EXECUTIVE SUMMARY

Two Different Questions, Often Confused

"What does a role see" has two separate answers in this system, and they don't always agree. The **sidebar** answer is simple: it's a menu-visibility setting, and it's correct and consistent — Agent sees Dashboard, Operations and Agent only; Staff sees everything except Settings; Admin and Superadmin see all of it. The **data** answer is the one that actually matters for privacy and correctness, and it's inconsistent: on the pages built most recently and most carefully (Leads, Quotations, Commissions, Invoices), an agent genuinely cannot see or touch another agent's records — the server checks, not just the menu. On several older pages that sit in the exact same sidebar group an agent already has access to, there is no check at all: hiding a link from the menu was the entire protection, and the underlying page answers every role identically.

LEADS / QUOTATIONS	COMMISSIONS / INVOICES	BOOKINGS / REQUESTS / CUSTOMERS	SETTINGS / CATALOG MUTATIONS
Done	**Done**	**Not done**	**Partial**
Ownership enforced on list, create, edit and delete. An agent cannot open or modify another agent's record even by URL.	Agent sees only their own figures. Rate-setting is admin-only, correctly excluding staff too.	No role check of any kind. Every role — including agent — sees and can edit every record, with no ownership filter anywhere in the query.	Four of five Settings pages correctly block non-admins by URL. One doesn't. A few catalog side-actions bypass their own page's save guard.

PART 1

What Each Role Sees in the Sidebar

This part is simple and already correct — stated here for context before the data-access findings below.

ROLE	SIDEBAR GROUPS VISIBLE
Superadmin	Everything — all 10 groups: Dashboard, Operations, Communications, Catalog, Field Operations, People & Partners, Analytics, Agent, Gallery, Settings.
Admin	Identical to Superadmin — no distinction between these two roles anywhere in the nav or, as far as this review found, anywhere in the server-side checks either.
Staff	Everything *except* Settings. Otherwise identical to Admin.
Agent	Only Dashboard, Operations, and Agent. Operations includes Bookings, Requests, Quotations, Invoices, Customers and Messages — several of which, per Part 2 below, are not actually scoped to the agent despite living in the one group agents are meant to use for their own work.

Mechanism: `layouts/admin.php`'s role filter, built on `AuthMiddleware::isAgentRole()` and a staff-only `unset($groups['Settings'])`. `AuthMiddleware` itself has no `isStaffRole()` — staff is simply "not agent, not specially restricted."

PART 2

What's Actually Enforced, Page by Page

This is the real question: regardless of what the menu shows, does opening or submitting a page actually limit an agent to their own data? Done where the server checks it; not done where the menu is the only thing standing in the way.

Done — ownership genuinely enforced

DONE

Leads

An agent's list is filtered to `agent_id=?`. Creating a lead force-sets `agent_id` to the logged-in agent — they cannot attribute a new lead to anyone else. Moving a lead through its pipeline stage is re-checked against ownership at the point of the update, not just on the list. Deleting a lead is blocked for agents entirely (staff and admin can).

`admin/leads.php:11, 36, 81–83, 102 · app/Services/PipelineSync.php:89`

DONE

Quotations

Two independent checks, not one: opening someone else's quotation by URL (`?id=X`) redirects with "Permission denied" before the page renders anything; saving is checked again, separately, before

the write executes. A newly created quotation is force-attributed to the logged-in user. The list, its status updates, and its delete action are all filtered to `created_by=?` for agents.

`admin/quotation_new.php:21–22, 85–91, 267 · admin/quotations.php:20, 85, 106–108`

DONE

Commissions

An agent's list and summary are filtered to their own `agent_id`. Approving or marking a commission paid is blocked for agents entirely. Setting someone's commission *rate* is the one action in this entire system gated to admin/superadmin specifically — staff is correctly excluded from that one, even though staff is otherwise unrestricted almost everywhere else.

`admin/commissions.php:21, 77, 94, 113`

DONE

Invoices

Bookings themselves have no owner column, so this page derives ownership by joining through the booking's linked quotation and commission records — a deliberate, documented design choice, and it works: an agent's invoice view is correctly limited to bookings tied to their own quotations or commissions.

`admin/invoices.php:24–29, applied at 40, 67, 86`

DONE

Dashboard

Agent gets an entirely separate "My Dashboard" view — every figure on it (leads, quotations, commissions, invoices, recent records) is scoped to that agent, and the code path exits before it could ever fall through to the shared business-wide dashboard below it. Staff and Admin see the identical full dashboard — there is no staff-specific reduction here, consistent with staff's "full access minus Settings" model.

`admin/index.php:14–37, exits at 187–188`

Not done — same data, every role

GAP

Bookings — zero role check anywhere in the file

Not partially scoped — *absent*. No `agent_id`, no `created_by`, no role check of any kind appears anywhere in this 405-line file. Every role sees every booking. More specifically: the action that changes a booking's payment status has no ownership check either, so an agent can mark any booking — not just one tied to their own sale — as fully paid. That specific action now also auto-triggers the invoice email and commission logic built this session, so this gap is not just a privacy issue; it's a path for an agent to trigger financial side effects on a sale that isn't theirs. Bookings sits

inside the Operations group agents already see in their sidebar, so this is reachable today, not a hypothetical.

`admin/bookings.php — grep for isAgentRole/agent_id/created_by returns nothing in the file`

GAP

Custom Safari Requests — zero role check

Same shape as Bookings: no ownership column, no role check, no filtering. Any role can view and change the status of any request. Also inside the Operations group an agent already has in their sidebar.

`admin/custom_requests.php — no isAgentRole/isAdminRole call anywhere in the file`

BY DESIGN

Customers — unrestricted, and this one is intentional

Confirmed unchanged from an earlier, deliberate decision: a shared contact record naturally has no single owner — the same repeat customer may legitimately be handled by different agents across different bookings over time, so this page was never meant to be scoped the way Leads or Quotations are. Listed here for completeness, not as a defect — but worth knowing it's a choice, not an oversight, if anyone ever asks "why can an agent see every customer."

`admin/customers.php — no role check anywhere, by design`

PART 3

Settings & Catalog — the Menu Isn't the Only Door

These pages aren't about per-agent data scoping — they're shared business configuration that should simply be admin-only. Four of the five Settings pages enforce that correctly even if someone navigates straight to the URL. One doesn't.

PAGE	HIDDEN FROM STAFF/AGENT NAV?	ACTUALLY BLOCKED IF THEY VISIT THE URL DIRECTLY?
Users	Yes	✓ **Yes** — redirects non-admins
Activity Log	Yes	✓ **Yes**
Seasons	Yes	✓ **Yes**
Park Fees	Yes	✓ **Yes**

PAGE	HIDDEN FROM STAFF/AGENT NAV?	ACTUALLY BLOCKED IF THEY VISIT THE URL DIRECTLY?
Currencies	Yes	✗ **No** — only the generic "must be logged in" check. Staff or Agent can open it *and submit the save form*, inserting or editing exchange rates, with the sidebar link being the only thing that was ever stopping them.

Two smaller catalog gaps

- **Packages — activate/deactivate toggle has no role guard.** The main package editor correctly blocks agents from saving pricing changes (and the UI shows them a clear "view only" notice instead of a save button) — but the separate toggle that flips a package active/inactive is a plain form post with no role check at all, so an agent can still take a package on or off the live site directly.
- **Package editor — the link/unlink-itinerary actions aren't covered by the save guard.** The guard that blocks agents from saving package pricing only covers the save form. Two other actions on the same page — detaching a package from its itinerary template, and attaching it to a different one — are triggered by a plain link and have no guard of their own, so an agent who knows the URL pattern can still change which itinerary prices a package.

REFERENCE

Full Matrix

PAGE	ROLE CHECK AT ALL?	AGENT SEES ONLY THEIR OWN RECORDS?	AGENT BLOCKED FROM EDITING OTHERS'?
Leads	**Yes**	**Yes**	**Yes**
Quotations	**Yes**	**Yes**	**Yes**
Commissions	**Yes**	**Yes**	**Yes (can't touch any, own included)**
Invoices	**Yes**	**Yes (derived)**	— (read-only view)
Bookings	**No**	**No**	**No**
Custom Requests	**No**	**No**	**No**
Customers (by design)	**No**	**No**	**No**
Packages — view	n/a, shared catalog	—	—

PAGE	ROLE CHECK AT ALL?	AGENT SEES ONLY THEIR OWN RECORDS?	AGENT BLOCKED FROM EDITING OTHERS'?
Packages — save pricing	**Yes**	—	**Yes**
Packages — activate toggle	**No**	—	**No**
Package editor — link/unlink	**No**	—	**No**
Users / Activity Log / Seasons / Park Fees	**Yes, admin-only**	n/a	n/a
Currencies	**No**	n/a	**No**
Profitability / Agent Performance dashboards	**Yes, admin-only**	n/a	n/a
Main Dashboard	**Yes**	**Yes (separate view)**	read-only

Every line above is sourced to an exact file and line number during this review. No code was changed as part of producing this report.